

AMAZONTECH - Gerencia de Infraestrutura e Seguranca

RELATORIO TECNICO - Laboratorio 06B

Auditoria dos Privilegios Administrativos

Equipe: Josias Bentes, Keven Coimbra, Margefson Barros e Nattan Lobato

Curso: Windows e Linux Hardening | Data: 06/08/2026 | Estacao: WIN-ADM-01 (MachadoPC)

1. Objetivo da Auditoria

Apos inventariar identidades (Lab 06A), auditar **quais acoes** cada identidade pode executar no Windows — privilegios administrativos, User Rights Assignment e conteudo do Access Token — avaliando conformidade com o principio do menor privilegio, sem alterar configuracoes. Privilegios controlam operacoes no SO (shutdown, backup, take ownership, drivers); diferem das permissoes NTFS (acesso a recursos).

2. Ferramentas Utilizadas

Ferramenta	Finalidade
whoami /priv	Privilegios presentes no Access Token
secpol.msc / secedit	User Rights Assignment (politica local)
gpedit.msc	Políticas locais de seguranca / comportamento
whoami /all	Correlacionar identidade, grupos e privilegios
PowerShell	Automacao e consulta administrativa
MMC	Centralizar snap-ins administrativos
Event Viewer / Get-WinEvent	Eventos relacionados a privilegios/seguranca
Consolidacao	Sintese da auditoria e recomendacoes

3. Evidencias Produzidas

Terminal - Evidencia 1 - Ambiente WIN-ADM-01

```
PS> hostname; whoami; Get-Date
MachadoPC
machadopc\marge

quinta-feira, 6 de agosto de 2026 19:47:49
OS: Microsoft Windows 11 Home Single Language | Version: 10.0.26200 | Build: 26200
Estacao: WIN-ADM-01 (MachadoPC) | Lab 06B - Privilegios
```

Figura - Evidencia 1 - Ambiente WIN-ADM-01

```
Terminal - Evidencia 2 - whoami /priv

PS> whoami /priv

INFORMAÇÕES DE PRIVILÉGIOS
-----

Nome de privilégio      Descrição                                Estado
=====
SeShutdownPrivilege     Desligar o sistema                      Desativado
SeChangeNotifyPrivilege Ignorar a verificação completa          Ativada
SeUndockPrivilege        Remover o computador da base de encaixe Desativado
SeIncreaseWorkingSetPrivilege Aumentar conjunto de trabalho de processo Desativado
SeTimeZonePrivilege      Alterar fuso horário                    Desativado

PS> Resumo: privilegios listados na sessao atual (token filtrado UAC)
Linhas com estado Ativada/Enabled approx: 1
Linhas com estado Desativado/Disabled approx: 4
Unico privilegio tipicamente ativo em sessao media: SeChangeNotifyPrivilege
SeShutdownPrivilege presente mas Desativado (nao elevado)
```

Figura - Evidencia 2 - whoami /priv

```
Terminal - Evidencia 3 - User Rights (secpol/secedit)

PS> # Equivalente documental a secpol.msc > Local Policies > User Rights Assignment
PS> secedit /export /areas USER_RIGHTS

Você não possui permissões suficientes para executar este comando, Verifique se você é o administrador local ou se abriu o prompt de comando usando a opção 'Execu

# Export bloqueado sem elevacao (esperado na sessao filtrada).
# Achados correlatos sem alterar politica:
# - whoami /priv mostra privilegios EFETIVOS do Access Token atual
# - Get-LocalGroupMember Administradores: MachadoPC\Administrador, MACHADOPC\marge
# - UAC EnableLUA=1 (ConsentPromptBehaviorAdmin=5) => elevacao sob demanda
# - gpedit.msc/secpol.msc AUSENTES no Windows 11 Home (edicao do lab)
#
# Privilegios tipicos de User Rights Assignment a auditar em Enterprise/Server:
# SeDebugPrivilege, SeTakeOwnershipPrivilege, SeBackupPrivilege, SeRestorePrivilege
# SeLoadDriverPrivilege, SeTcbPrivilege, SeImpersonatePrivilege
# SeShutdownPrivilege, SeRemoteInteractiveLogonRight, SeDenyInteractiveLogonRight
#
# Recomendacao AmazonTech: executar secpol/secedit elevado em janela autorizada
# e revisar atribuicoes diretas a usuarios (preferir grupos).
```

Figura - Evidencia 3 - User Rights (secpol/secedit)

```
Terminal - Evidencia 4 - gpedit/secpol + UAC

PS> # gpedit.msc / secpol.msc disponibilidade nesta edicao
gpedit.msc presente: False
secpol.msc presente: False

PS> Get-CimInstance Win32_OperatingSystem | Select Caption, OSArchitecture

Caption      : Microsoft Windows 11 Home Single Language
OSArchitecture : 64 bits
Version      : 10.0.22H2

# Windows 11 Home: gpedit/secpol podem estar ausentes.
# Evidencia alternativa: secedit /export USER_RIGHTS (shot 03) + whoami /priv.
# Políticas locais relevantes ao privilegio: UAC, User Rights, Audit Policy.

PS> Get-ItemProperty HKLM:\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System | Select EnableLUA, ConsentPromptBehaviorAdmin, FilterAdministratorToken

EnableLUA           : 1
ConsentPromptBehaviorAdmin : 5
ConsentPromptBehaviorUser  : 3
FilterAdministratorToken  :
PromptOnSecureDesktop     : 1
```

Figura - Evidencia 4 - gpedit/secpol + UAC

```
Terminal - Evidencia 5 - whoami /all

PS> whoami /all

INFORMAÇÕES DE USUÁRIO
-----

Nome de usuário SID
-----
machadopc\marge 5-1-5-21-2273054947-3814652866-1034022874-1001

INFORMAÇÕES DE GRUPO
-----

Nome do grupo                                     Tipo                                     SID
-----
Rótulo Obrigatório\Nível Obrigatório Médio      Rótulo                                S-1-16-8192
Todos                                             Grupo bastante conhecido             S-1-1-0
AUTORIDADE NT\Conta local e membro do grupo de Administradores Grupo bastante conhecido             S-1-5-114
BUILTIN\Administradores                        Alias                                S-1-5-32-544
BUILTIN\Usuários                              Alias                                S-1-5-32-545
AUTORIDADE NT\INTERATIVO                      Grupo bastante conhecido             S-1-5-4
LOGON de CONSOLE                              Grupo bastante conhecido             S-1-2-1
AUTORIDADE NT\Usuários autenticados            Grupo bastante conhecido             S-1-5-11
AUTORIDADE NT\Esta organização                 Grupo bastante conhecido             S-1-5-15
MicrosoftAccount\margefson@outlook.com        Usuário                              S-1-11-96-3623454863-58364-18864-2661722203-1597581903-3475737053-29212561
AUTORIDADE NT\Conta local                      Grupo bastante conhecido             S-1-5-113
LOCAL                                           Grupo bastante conhecido             S-1-2-0
AUTORIDADE NT\Cloud Account Authentication     Grupo bastante conhecido             S-1-5-64-36

INFORMAÇÕES DE PRIVILÉGIOS
-----

... (saída truncada) ...
```

Figura - Evidencia 5 - whoami /all

```
Terminal - Evidencia 6 - PowerShell + Administradores

PS> Get-Command *Security* | Measure-Object
Total cmdlets/funcões *Security*: 5

PS> Get-Command *Security* | Select-Object -First 25 Name, CommandType, Source

Name                                CommandType Source
----                                -
Get-NetFirewallSecurityFilter        Function NetSecurity
Set-NetFirewallSecurityFilter        Function NetSecurity
SecurityHealthHost.exe              Application C:\WINDOWS\system32\SecurityHealthHost.exe
SecurityHealthService.exe           Application C:\WINDOWS\system32\SecurityHealthService.exe
SecurityHealthSystray.exe            Application C:\WINDOWS\system32\SecurityHealthSystray.exe

PS> Get-LocalGroupMember -Group Administradores

Name                                ObjectClass PrincipalSource
----                                -
MachadoPC\Administrador             Usuário Local
MACHADOPC\marge                     Usuário MicrosoftAccount

PS> whoami /groups | findstr /i Administr
AUTORIDADE NT\Conta local e membro do grupo de Administradores Grupo bastante conhecido S-1-5-114
BUILTIN\Administradores             Alias S-1-5-32-544
```

Figura - Evidencia 6 - PowerShell + Administradores

```
Terminal - Evidencia 7 - MMC (paths/snap-ins)

PS> # MMC: centraliza snap-ins (Local Security Policy, Event Viewer, etc.)
PS> where.exe mmc
C:\Windows\System32\mmc.exe
PS> Test-Path mmc.exe / secpol / eventvwr
mmc: True
eventvwr.msc: True
secpol.msc: False

# Snap-ins típicos para auditoria de privilégios:
# - Security Templates / Local Security Policy (User Rights Assignment)
# - Event Viewer (Security log)
# - Computer Management (Local Users and Groups)
# Evidência obtida via secedit + whoami + Get-WinEvent (sem alterar config).
```

Figura - Evidencia 7 - MMC (paths/snap-ins)

```
Terminal - Evidencia 8 - Event Viewer / Get-WinEvent

PS> # Equivalente eventvwr.msc - logs de Segurança / Sistema
PS> Get-WinEvent -ListLog Security, System, Application | Select LogName, RecordCount, IsEnabled

LogName      RecordCount IsEnabled
-----
System       43010      True
Application   24754      True

PS> Get-WinEvent -LogName Security -MaxEvents 8 -ErrorAction SilentlyContinue | Format-Table TimeCreated, Id, LevelDisplayName, Message -Wrap
Security log: acesso limitado ou vazio (Tentativa de execução de uma operação não autorizada.)
PS> Get-WinEvent -LogName System -MaxEvents 8 | Select TimeCreated, Id, ProviderName

TimeCreated      Id ProviderName
-----
06/08/2026 19:46:24 10016 Microsoft-Windows-DistributedCOM
06/08/2026 19:45:50 10016 Microsoft-Windows-DistributedCOM
06/08/2026 19:42:06 10016 Microsoft-Windows-DistributedCOM
06/08/2026 19:42:06 10016 Microsoft-Windows-DistributedCOM
06/08/2026 19:42:06 10016 Microsoft-Windows-DistributedCOM
06/08/2026 19:42:06 10016 Microsoft-Windows-DistributedCOM
06/08/2026 19:42:03 10016 Microsoft-Windows-DistributedCOM
06/08/2026 19:38:29 10016 Microsoft-Windows-DistributedCOM

# Categorias típicas no Event Viewer: Application, Security, Setup, System, Forwarded Events
# Log Security registra logon, privilegio especial usado (4672), mudancas de politica, etc.
```

Figura - Evidencia 8 - Event Viewer / Get-WinEvent

```
Terminal - Evidencia 9 - Consolidacao da auditoria

=== CONSOLIDACAO AUDITORIA PRIVILEGIOS LAB 06B ===
Estacao: WIN-ADM-01 / MachadoPC
Usuario sessao: machadopc\marge
Data: 08/06/2026 19:48:23

1) Token (whoami /priv) - privilegios com estado Ativada:
SeChangeNotifyPrivilege      Ignorar a verificacao completa      Ativada

2) Membros Administradores:
MachadoPC\Administrador, MACHADOPC\marge

3) UAC EnableLUA: 1
ConsentPromptBehaviorAdmin: 5

4) Ferramentas: whoami/priv, secedit(negado sem elevacao), gpedit/secpol N/A Home,
whoami/all, PowerShell, MMC paths, Event Viewer (System OK; Security exige admin)

5) Inconsistencias vs menor privilegio:
- Conta diaria marge em Administradores (Lab 06A)
- Token filtrado: poucos privilegios ativos agora, mas elevacao disponivel
- Security log inacessivel sem admin (lacuna de auditoria operacional)
- Conta postgres habilitada - revisar logon rights

6) Recomendacoes: conta admin separada; JIT/UAC; export User Rights elevado;
habilitar/auditar 4672; seguir para Lab 06C (NTFS)
```

Figura - Evidencia 9 - Consolidacao da auditoria

4. Resultados Obtidos

4.1 Access Token — whoami /priv (Ex.1)

5 privilegios listados na sessao atual. **Ativada:** apenas **SeChangeNotifyPrivilege** (bypass traverse). **Desativados:** SeShutdownPrivilege, SeUndockPrivilege, SeIncreaseWorkingSetPrivilege, SeTimeZonePrivilege.

Relevancia: sessao em integridade media (UAC) — token filtrado. Mesmo sendo membro de Administradores, privilegios sensiveis nao estao todos Enabled ate elevacao. Ainda assim, a **capacidade de elevar** permanece (ConsentPrompt).

4.2 User Rights / Politicas locais (Ex.2–3)

secpol.msc / gpedit.msc: ausentes no Windows 11 Home desta estacao. **secedit /export USER_RIGHTS:** negado sem elevacao administrativa — evidencia do proprio controle de privilegio.

UAC: EnableLUA=1; ConsentPromptBehaviorAdmin=5; PromptOnSecureDesktop=1 — elevacao sob demanda com desktop seguro. Politicas locais reforcam comportamento de consentimento e reduzem uso acidental de privilegios elevados.

4.3 Correlacao identidade/grupos/privilegios (Ex.4–6)

whoami /all: confirma SID, grupos e privilegios no mesmo token. BUILTIN\Administradores com atributo de negacao na sessao filtrada.

PowerShell: Get-Command *Security* retornou 5 itens (NetSecurity + SecurityHealth*). Get-LocalGroupMember Administradores: **Administrador + marge**. Automacao padroniza auditorias repetidas.

MMC: mmc.exe disponivel; snap-ins tipicos: Local Security Policy, Event Viewer, Computer Management — centralizam a administracao sem alterar a politica nesta auditoria.

4.4 Event Viewer (Ex.7)

Logs Application e System habilitados (milhares de registros). Log **Security** inacessível na sessão não elevada (operação não autorizada) — lacuna operacional: eventos 4672 (privilegios especiais) exigem leitura administrativa. System amostrado (ex.: DCOM 10016). Categorias padrão: Application, Security, Setup, System, Forwarded.

5. Analise Tecnica

Grupos administrativos **nao sao** sinônimo de privilegios Enabled no token: o UAC filtra a sessao diaria. Porem o menor privilegio **nao esta plenamente aplicado** porque a conta de uso diario permanece no grupo Administradores (Lab 06A), permitindo elevacao permanente sob demanda.

Inconsistencias: (1) admin permanente na conta diaria; (2) export User Rights bloqueado sem elevacao / ferramentas ausentes no Home; (3) Security log ilegivel sem admin — dificulta investigacao de abuso de privilegio; (4) conta postgres habilitada sem revisao formal de logon rights.

Discussao: administrar privilegios corretamente reduz superficie de ataque e elevacao indevida; identidade + grupo + privilegio formam a cadeia de autorizacao.

6. Recomendacoes

#	Recomendacao	Prioridade
1	Conta diaria sem Administradores; admin nominativa + UAC/JIT	Alta
2	Em Enterprise/Server: auditar User Rights via secpol elevado	Alta
3	Preferir atribuicao de direitos a grupos, nao a usuarios	Alta
4	Garantir leitura do Security log para auditar 4672/mudancas	Media
5	Revisar logon rights da conta postgres (servico)	Media
6	Automatizar whoami/priv + inventario de grupos via PowerShell	Media
7	Avancar para Lab 06C (permissoes NTFS / ACL)	Alta

7. Conclusao / Parecer

Empresa	AmazonTech
Estacao	WIN-ADM-01 / MachadoPC
Escopo	Auditoria de privilegios (sem alteracao)
Data	06/08/2026
Equipe	Josias Bentes, Keven Coimbra, Margefson Barros e Nattan Lobato

A administracao observada esta **parcialmente compativel** com o menor privilegio: UAC reduz privilegios efetivos na sessao media, mas a associacao permanente ao grupo Administradores mantem superficie de elevacao. A auditoria produziu evidencias de token, grupos, UAC, limites da edicao Home e Event Viewer.

Parecer: [X] **AUDITORIA CONCLUIDA — APTO PARA AVANCAR AO LAB 06C (NTFS)** com plano de reorganizacao de privilegios.

Responsavel: Josias Bentes, Keven Coimbra, Margefson Barros e Nattan Lobato

Data: 06/08/2026

Checklist Final

Item	OK?
whoami /priv analisado	SIM
User Rights / secpol (ou equivalente documentado)	SIM
gpedit/UAC / politicas locais	SIM
whoami /all correlacionado	SIM
PowerShell + MMC documentados	SIM
Event Viewer / Get-WinEvent	SIM
Consolidacao + recomendacoes + parecer	SIM
Nenhuma configuracao alterada	SIM

Screenshots: lab06b/evidencias/shots/img/ | Scripts: lab06b/scripts/